

VERISTACK

A PRACTITIONER'S FIELD GUIDE

Governing Agentic AI in Regulated Finance

How to keep autonomous agents controlled, auditable, and regulator-ready, with a proven seven-gate control model you can apply this quarter.

The one-page version

Agentic AI has crossed from pilots into production in finance. The systems now search, reason, and act. They move money, approve customers, and file reports. They no longer simply answer.

The moment an agent can *act*, the governance question changes. It stops being "is the model accurate" and becomes "can I prove every decision was controlled." Regulators will not accept "the AI decided." An examiner from OSFI, the CBN, or a model-risk review under SR 11-7 will ask three questions. Who was accountable. What the control was. Where the audit trail is.

This guide gives you a concrete answer. It presents a control model of seven independent gates that every agentic decision should pass through before an action executes. It walks one real transaction through all seven. It hands you a readiness checklist you can run against your own deployment this week, and a ninety-day path to get from principle to proof.

In regulated finance, trust is not a model property. It is a proof property. You earn it by showing control, accountability, and an audit trail on every autonomous decision.

What is inside

01	The Shift Nobody Governed For
02	The Anatomy of a Governed Agentic Decision
03	From Principle to Proof, a Worked Example
04	Where Platforms Stop and Governance Must Begin
05	Your Readiness Checklist
06	A Ninety-Day Path to Governed Agentic AI

The Shift Nobody Governed For

For two years, most AI governance in financial services was written for a world that no longer exists. It governed models that produced text. A model summarised a document, drafted a memo, or answered a question, and a human decided what to do next. The human was always the actor. The model was an advisor.

Agentic AI breaks that assumption. An agent does not stop at a suggestion. It searches, reasons, and then acts across your data and your tools. It can initiate a payment, approve an onboarding, escalate a case, or file a report. The human is no longer guaranteed to be in the loop, because the system was designed to close the loop on its own.

That single change breaks most existing governance, because a checklist built to ask "is this model fair and accurate" was never built to ask "did this system take an action it was not permitted to take."

Three things change when an agent can act

Irreversibility. A wrong sentence in a draft is edited. A wrong payment is gone. When the output is an action rather than a suggestion, the cost of a mistake is no longer a bad paragraph. It is a real-world consequence that may not be recoverable.

Chaining. In a multi-agent system, one agent's output becomes the next agent's input. A small error early in the chain does not stay small. It compounds. By the time it reaches the action, a low-confidence guess can be wearing the costume of a confident decision.

Delegated authority. An agent that acts is acting as someone, using someone's permissions. The question of "who was allowed to do this" becomes urgent, because the entity pressing the button is not a person you can hold to account in the usual way.

WHY "RESPONSIBLE AI" IS NOT ENOUGH ANYMORE

Responsible-AI programmes govern the model. Fairness, transparency, and accuracy are necessary, and they remain important. But they say nothing about whether a specific action was authorised, controlled, and recorded. Agentic finance needs to govern the decision and the action, not only the model that informed them.

The regulator is already asking

This is not a future concern. The expectations already exist in the frameworks that examine you today. OSFI's model-risk guidance and its expectation of a clear three-lines-of-defence structure. Model validation and ongoing monitoring under SR 11-7. Human oversight expectations woven through emerging AI rules. The Central Bank of Nigeria's tiered escalation and reporting mandates for institutions operating there. Each of them, in its own language, asks the same thing. Show me the control, show me who owned the decision, and show me the record.

The question is no longer "can I trust the model." It is "can I prove I controlled what the agent did."

The Anatomy of a Governed Agentic Decision

If the risk lives in the action, then governance has to live in the path to the action, not in a report written afterwards. The core idea of this guide is simple. Between the moment an agent decides and the moment an action executes, the decision must pass through a governance layer. That layer is made of gates.

A gate is an independent check with exactly three possible outcomes. It can **pass** the decision and let it continue. It can **escalate** it to a human authority. Or it can **block** it outright. The gates are ordered, and any single gate can stop the whole decision. No agent output is allowed to bypass them. This is defense in depth, applied to agent actions.

Through building and running governed multi-agent systems in production, VeriStack settled on seven gates. They are not arbitrary. Each one closes a specific way an autonomous decision can go wrong, and each one maps to an expectation a regulator already holds. Figure 1 on the following page shows the full model. The table below names each gate and what it prevents.

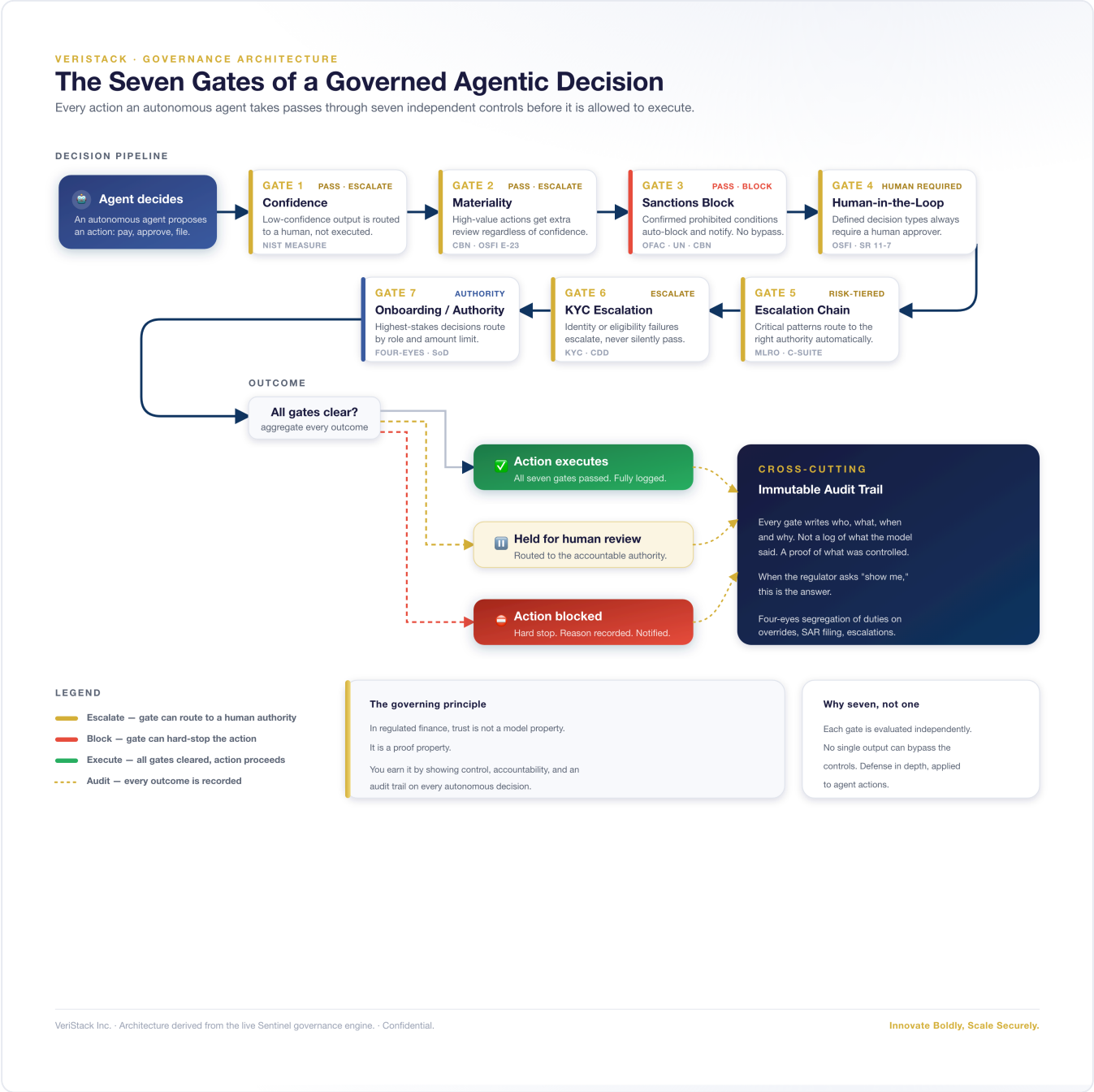
The seven gates

#	Gate	What it prevents	Regulatory anchor
1	Confidence	Acting on an uncertain guess. Low-confidence output routes to a human.	NIST MEASURE
2	Materiality	A large action slipping through on autopilot. High value gets extra review.	OSFI E-23, CBN
3	Hard-Stop Block	A prohibited condition proceeding. Confirmed hits auto-block, no override.	OFAC, UN, CBN
4	Human-in-the-Loop	A high-stakes decision type executing without a person. A human must approve.	OSFI, SR 11-7
5	Escalation Chain	The wrong person deciding. Risk-tiered routing to the right authority.	CBN tiered policy
6	Eligibility Escalation	An identity or eligibility failure passing silently. It escalates instead.	KYC, CDD
7	Authority Gate	A decision routed below its required approval level. Routes by role and limit.	Four-eyes, SoD

WHY SEVEN, AND WHY INDEPENDENT

Each gate is evaluated on its own. A decision can clear the confidence gate and still be blocked at sanctions. It can pass materiality and still be held because a human approval is mandatory for that decision type. Independence is the point. No single clever output can talk its way past the controls, because there is no single control to talk past.

Figure 1. The seven gates of a governed agentic decision



Every agentic action passes through seven independent gates before it is allowed to execute. Any gate can pass, escalate to a human, or block. The immutable audit trail cross-cuts all of them.

This is a framework, not a feature

The seven gates are not one product's plumbing. They are a reusable control model that VeriStack applies across every agentic system it builds. The same seven gates run today across anti-money-laundering compliance, invoice intelligence, accounting close, and facilities maintenance. What changes between them is not the architecture. It is the configuration.

Four of the seven gates travel unchanged. Confidence, Materiality, Human-in-the-Loop, and the Escalation Chain apply to almost any agent that touches money or makes a judgement. The other three, Hard-Stop Block, Eligibility Escalation, and the Authority Gate, travel as patterns with a domain-specific rule dropped in. A sanctions list in one domain is a duplicate-invoice check in another and a safety-compliance flag in a third. The gate is the same. The list is configuration.

Roughly ninety percent of the control architecture is reused across domains. Only about ten percent, the thresholds, the lists, and the regulatory bindings, is configured per use case.

This matters to you as a buyer or a builder for one reason. A governance model that has already proven portable across four production domains is not a theory you are being asked to trust. It is a method with a track record. Methods scale. One-offs do not.

From Principle to Proof, a Worked Example

A framework earns its keep when you watch it work. So let us take a single realistic decision and follow it through all seven gates. This is the kind of trace that separates a governed system from a system that merely produces logs.

THE SCENARIO

A newly onboarded customer initiates a large cross-border payment. An agent has screened it, and its name partially matches an entry on a sanctions list. In an ungoverned system, the speed of automation is exactly what makes this dangerous. In a governed system, the seven gates turn that same speed into a controlled, recorded, defensible outcome.

The decision, gate by gate

- 1 Confidence Gate.** The screening agent reports a confidence above the threshold. The gate passes. Had the agent been uncertain, the decision would have been routed to a human here, before anything else happened.
- 2 Materiality Gate.** The payment amount exceeds the materiality threshold for this institution. The gate fires and flags the transaction for additional review, regardless of how confident the agent was. Size alone earns scrutiny.
- 3 Hard-Stop Block.** The sanctions match is confirmed. This is a prohibited condition. The gate issues a hard block. The payment cannot proceed automatically, and no agent can override it. A notification fires at the same moment.
- 4 Human-in-the-Loop.** Because a sanctions decision is a mandatory human-approval decision type, a qualified person must now review it. The system does not, and cannot, clear it on its own.
- 5 Escalation Chain.** The risk tier of this case routes it automatically to the right authority. A confirmed sanctions match does not go to a junior analyst. It reaches the compliance officer, and where the profile warrants it, the MLRO.
- 6 Eligibility Escalation.** The customer is newly onboarded, so identity and eligibility carry extra weight. Any KYC gap escalates rather than resolving quietly in the background.
- 7 Authority Gate.** Finally, the override itself is governed. Lifting a sanctions block is not a one-person decision. A four-eyes, segregation-of-duties check requires a second authorised approver before any override can take effect.

The part that satisfies a regulator

Every one of those gate outcomes is written to an immutable audit trail. Not a transcript of what the model said. A record of what was controlled, who was accountable, when it happened, and why. When an examiner asks to see how a sanctions-adjacent payment from a new customer was handled, the institution does not reconstruct a story from fragments. It produces the trace.

Most platforms give you auditable outputs, a log of what the model produced. A governed agentic system gives you a proof of what was controlled and who was accountable. Those are not the same thing.

This example is drawn from a live, tested implementation, not a thought experiment. The gates, the mandatory human approval on sanctions, the risk-tiered escalation to the compliance officer and MLRO, and the four-eyes check on overrides are all real, running controls.

Where Platforms Stop and Governance Must Begin

The current generation of enterprise AI platforms solves real and important problems. Private deployment inside your own virtual private cloud or on-premises. Data residency and data autonomy, so your information never leaves your control. Auditable outputs, secure infrastructure, and certified security standards. These are not small things, and the platforms that deliver them deserve credit. If you have deployed one, you have done something sensible.

But their governance is horizontal and generic by design, and it has to be. A platform built to serve every industry at once cannot ship a materiality threshold tuned to a specific regulator, a four-eyes check written for suspicious-activity-report filing, or an escalation chain that knows the difference between a compliance officer and an MLRO. That is not a criticism of those platforms. It is simply not their job.

THE GAP IN ONE LINE

Deployment security answers "is my data safe." Decision governance answers "can I prove my agents acted within control." You need both. Most institutions have bought the first and have not yet realised the second is missing.

Governance is a layer, not a competitor

The right mental model is not platform versus governance. It is governance on top of platform. A control layer that sits above whatever agent platform and whatever model you run, watching the decisions, applying the gates, and producing the proof. It is model-agnostic and cloud-agnostic by intent, because your governance should not be hostage to a single vendor's model.

So if you have already deployed a private agent platform, good. You solved the deployment problem. The next question is the one this guide exists to answer. Now that your agents can act, how do you prove that what they do stays within control. That is where governance begins, and it begins exactly where the platform's responsibility ends.

Deployed a private agent platform already? Good. Now govern what it does.

Your Readiness Checklist

Before you buy or build anything, you can measure where you stand. The following checklist runs across five governance dimensions, each mapped to the frameworks that examine you. Answer honestly. The gaps you find are your roadmap.

1. Governance and accountability

Maps to NIST GOVERN, ISO 42001 Clause 5, OSFI governance expectations.

- Is there a single named owner for AI governance, not an informal shared understanding?
- Is there a written policy that defines what your agents are and are not allowed to do?
- Does a committee or role actually review agentic use cases before they go live?

2. Risk and impact assessment

Maps to NIST MAP, ISO 42001 AI impact assessment.

- Do you assess the risk of an agentic use case before deploying it, not after an incident?
- Have you identified which of your agent actions are irreversible or high-materiality?
- Do you know which decisions your agents make autonomously today, without a human?

3. Data and model controls

Maps to SR 11-7, OSFI E-23, NIST MEASURE.

- Are the models behind your agents validated, and is that validation documented?
- Is there a confidence threshold below which an agent must defer to a human?
- Is data quality controlled at the point the agent consumes it?

4. Transparency and oversight

Maps to NIST trustworthy-AI characteristics and human-oversight expectations.

- Is there a genuine human in the loop for your highest-stakes decision types?
- Can you produce an audit trail showing who was accountable for a given decision?
- Can you explain, to an examiner, why a specific agent action was allowed or blocked?

5. Compliance and monitoring

Maps to ISO 42001 Clause 9, OSFI B-13, ongoing-monitoring expectations.

- Do you monitor your agents in production, not only in testing?
- Do you track regulatory change and map it back to your controls?
- Is there a segregation-of-duties check on your most sensitive overrides?

SCORE YOURSELF

Count your clear "yes" answers. Twelve or more, you are Managed to Mature and should focus on proof and audit depth. Seven to eleven, you are Developing and have real gaps to close before scaling. Six or fewer, you are At Risk, and the safest next step is to slow autonomous action until the gates are in place.

Want your score calculated instantly, with your top three gaps mapped to specific fixes? Take the free VeriStack Readiness assessment at **veristack.ca/readiness**.

A Ninety-Day Path to Governed Agentic AI

You do not need to boil the ocean. You need to govern your highest-risk use case first, prove it, and then repeat the pattern. Ninety days is enough to go from principle to proof on one meaningful decision path.

Days 1 to 30, See

Inventory your agentic use cases. For each one, map what the agent can actually do, and mark every action that is irreversible or high in materiality. You cannot govern what you have not catalogued. The output of this phase is a ranked list of where the real risk lives.

Days 31 to 60, Gate

Take your top-risk use case and define its gates. Wire in the confidence threshold, the materiality trigger, the mandatory human approvals, and the escalation routing. Configure the hard-stop conditions and the authority limits for that domain. This is the ten percent of configuration on top of the ninety percent of reusable control model.

Days 61 to 90, Prove

Stand up the audit trail so every gate outcome is recorded. Then run a mock regulator review against that one use case. Ask your own team the three questions an examiner will ask, who was accountable, what was the control, where is the record, and close whatever gaps the exercise exposes.

WHAT YOU HAVE AT DAY NINETY

One governed, audit-ready decision path, and a repeatable pattern for the next one. That is exactly the shape of a VeriStack Trust engagement, and it is designed so that the second use case is faster than the first.

Trust is a proof property

If you take one idea from this guide, take this. In regulated finance, trust is not something your model has. It is something you demonstrate, on every autonomous decision, by showing control, accountability, and an audit trail. The seven gates are how you deliver that proof once and reuse it everywhere.

Three ways to start, by how far you want to go

Start free

Take the VeriStack Readiness assessment at veristack.ca/readiness and see exactly where you stand across the five dimensions.

Go one step further

Book a free thirty-minute governance gap call. Bring your riskiest agentic use case and we will map its gates with you.

Bring in VeriStack Trust

A full engagement, Assessment, Framework, or ongoing Retainer, to design and prove the control model across your systems.

About VeriStack

VeriStack is a governance specialist for agentic AI in regulated industries, founded by a financial-services governance practitioner with roughly a decade in banking and data and AI governance. VeriStack builds and governs production multi-agent systems, including a live governed anti-money-laundering platform, and applies one reusable seven-gate control framework across every build.

Innovate Boldly, Scale Securely.

Frameworks referenced: NIST AI Risk Management Framework, ISO 42001, OSFI E-23 and B-13, SR 11-7, and CBN anti-money-laundering directives. This guide is practitioner guidance and does not constitute legal or regulatory advice.